



CYBERSICUREZZA AZIENDALE

GUIDA PER I DIRIGENTI



AGENZIA PER
LA CYBERSICUREZZA
NAZIONALE

Le iniziative di promozione della cybersicurezza aziendale sono fondamentali per essere consapevoli del ruolo chiave che la cybersicurezza riveste nella transizione digitale.

Molte realtà aziendali non hanno ancora intrapreso un percorso adeguato per proteggere i propri processi, oppure hanno adottato soluzioni solo parziali. Questa situazione è spesso causata dalla mancanza di una pianificazione strutturata e, soprattutto, alla scarsa priorità assegnata alle misure volte a potenziare la capacità di prevenzione, monitoraggio e contrasto delle minacce informatiche, in relazione al livello di esposizione ai rischi.

4,5 milioni
di PMI
sempre più a rischio di
attacchi
informatici

Le piccole e medie imprese (PMI) Italiane (circa 4,5 milioni di imprese¹) rappresentano un asse portante del motore economico del Paese. Molte di esse operano nelle filiere di operatori pubblici e privati che gestiscono infrastrutture critiche nazionali. Le analisi condotte dal Computer Security Incident Response Team (CSIRT Italia) dell'Agenzia per la Cybersicurezza Nazionale, insieme alle statistiche ufficiali e ai principali report di settore, evidenziano come **gli attacchi informatici ai danni delle PMI siano in costante aumento**².

L'uso preponderante di malware, ransomware e phishing, evidenzia come il cyber crimine sfrutti sempre più l'impreparazione in termini di cybersicurezza e l'errore umano a proprio vantaggio.

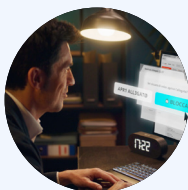
¹ ISTAT, Registro statistico delle imprese attive (2023), includendo le imprese con numero di addetti minore di 10 (microimprese) e le imprese con numero di addetti tra 10 e 250.

² Eurostat, Security incidents and consequences by size class of enterprise (2024); Nel 2024 il 15,8% delle imprese con numero di addetti tra 10 e 250 ha riportato di aver avuto nel corso dell'anno precedente almeno un problema di sicurezza ICT che ha determinato un impatto tra indisponibilità di servizi ICT, distruzione o corruzione dei dati, divulgazione di dati riservati (contro il 9,9% nel 2019).

Pertanto è essenziale che le PMI aumentino il loro presidio di sicurezza riducendo l'esposizione alle minacce informatiche e mitigando gli impatti di eventuali attacchi cyber, al fine di salvaguardare la produttività.

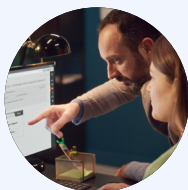
In questa prospettiva, oltre alle misure tecniche, **assumono rilevanza cruciale anche quelle organizzative e procedurali, dove la consapevolezza e la formazione**, così come la pianificazione dei processi per la gestione delle crisi e il controllo della catena di approvvigionamento (la c.d. supply chain), svolgono un ruolo centrale.

È quindi fondamentale diffondere una buona cultura della cybersicurezza a tutti i livelli dell'organizzazione:



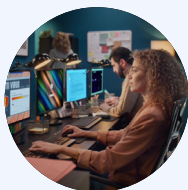
DIRIGENTI D'AZIENDA

affinché **pianifichino**, attraverso l'allocazione di budget e risorse, **l'acquisto di servizi e infrastrutture, e promuovano corsi di formazione o altre iniziative di sensibilizzazione** volte al potenziamento di una cultura della cybersicurezza.



PROFESSIONISTI IT

affinché **proteggano l'organizzazione dai rischi cyber, individuando, supportati dalla dirigenza, adeguate misure ed iniziative di sicurezza** atte a prevenire o ridurre le conseguenze di eventuali incidenti cyber, in conformità con le normative vigenti.



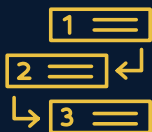
DIPENDENTI

affinché **collaborino per il mantenimento della cybersicurezza aziendale partecipando alle iniziative di formazione e adottando le precauzioni suggerite dall'organizzazione** al duplice scopo di tutelarsi dalle minacce e di contribuire in modo positivo al loro riconoscimento e alla mitigazione dei relativi impatti sull'organizzazione.

È fondamentale promuovere una maggiore consapevolezza in ambito cyber a tutti i livelli dell'organizzazione, adattando contenuti e approcci formativi ai diversi ruoli, competenze e responsabilità connesse ai processi aziendali, **riducendo così l'esposizione ai rischi informatici e la possibilità di incorrere in sanzioni per mancata conformità ai requisiti normativi**. Nei paragrafi seguenti sono riportate le principali indicazioni rivolte ai dirigenti, utili a comprendere i vantaggi e l'importanza di includere la cybersicurezza tra le priorità strategiche dell'azienda, destinando risorse e un adeguato budget per:

- **adottare un programma di formazione e consapevolezza;**
- **gestire le crisi e controllare la catena di approvvigionamento;**
- **proteggere il patrimonio informativo;**
- **mantenere un'infrastruttura ICT resiliente;**
- **favorire l'innovazione offerta dalle tecnologie emergenti.**

La guida supporta la dirigenza delle PMI nell'individuazione di possibili iniziative cyber da integrare nel contesto organizzativo, definendo gli adeguati presidi in materia di cybersicurezza e orientando la capacità di spesa in maniera mirata e più consapevole. Tali iniziative e presidi di sicurezza vanno individuati coerentemente con gli obiettivi strategici e sono rivolti a sostenere la resilienza e la continuità dei servizi erogati. Per ciascun argomento, si riportano:



Una **sintesi** (o elenco di “**azioni chiave**”) che raccoglie i principali messaggi e comportamenti raccomandati in materia di cybersicurezza.



Contenuti in dettaglio: indicazioni operative strutturate sotto forma di linee guida.

N.B. Nel contesto di questo documento, per **informazioni riservate** si intendono **tutte quelle informazioni** trattate all'interno dei processi aziendali per cui è determinante garantire confidenzialità, e **la cui diffusione non autorizzata, alterazione, perdita può comportare un danno significativo per l'azienda e/o per i clienti e/o per altre parti coinvolte**. Queste informazioni possono includere dati personali, informazioni finanziarie, strategie aziendali, proprietà intellettuale, brevetti e altre informazioni. Tra le informazioni riservate sono incluse anche le cosiddette informazioni critiche ovvero le informazioni considerate particolarmente rilevanti per l'operatività e lo svolgimento del business dell'organizzazione.

1

Stabilisci gli obiettivi e diffondi la cultura della cybersicurezza

AZIONI CHIAVE

1. Definisci obiettivi di sicurezza rilevanti, assicurandoti che siano allineati con gli obiettivi strategici della tua organizzazione.

2. Individua gli obiettivi di sicurezza in fase di pianificazione strategica, prima di implementare nuovi servizi, sistemi o tecnologie e garantisci che siano rivisti periodicamente nel tempo.

3. Integra la sicurezza nella cultura organizzativa, promuovendo la

consapevolezza, a tutti i livelli, dell'impatto che una violazione dei dati o una compromissione dei sistemi può comportare.

4. Comunica al personale il valore delle buone pratiche di sicurezza, evidenziando come la cultura della cybersicurezza rappresenti un investimento strategico per l'impresa.

CONTENUTI DI DETTAGLIO

Per garantire adeguati livelli di resilienza alle minacce cyber **è fondamentale che la dirigenza di ogni PMI definisca, anche con il supporto di un responsabile per la cybersicurezza, gli obiettivi e le strategie di sicurezza chiari e coerenti con le esigenze dell'organizzazione.**

La sicurezza deve essere considerata un'attività non occasionale. È quindi essenziale stabilire, almeno su base annuale, un insieme mirato di obiettivi di sicurezza che siano rilevanti e allineati con il modello di business e le strategie di crescita aziendale, così da individuare le iniziative necessarie al loro raggiungimento e garantirne il monitoraggio nel tempo.

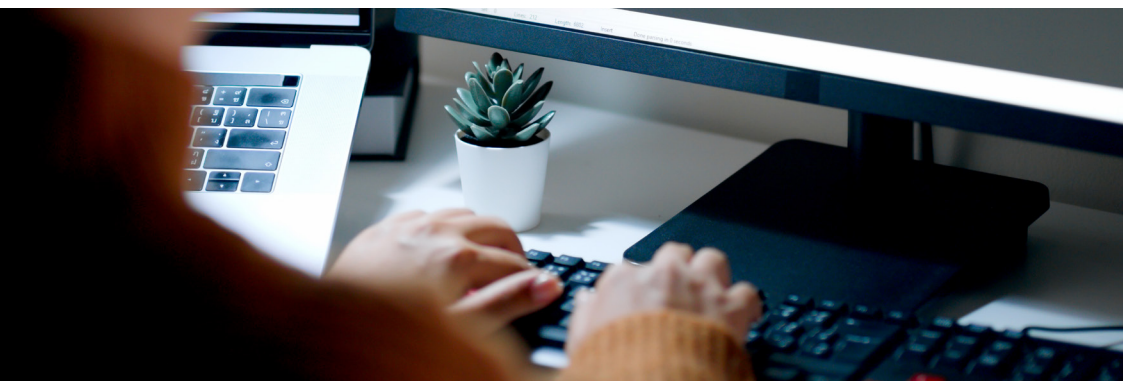


Questi obiettivi possono includere:

- **L'implementazione di misure** rivolte alla continuità dei processi produttivi chiave, finalizzate a **prevenire impatti sulla riservatezza, integrità e disponibilità** dei dati trattati.
- **Il monitoraggio e il rilevamento delle minacce.**
- **La gestione efficace di eventuali incidenti di sicurezza.**
- **La conformità normativa**, garantendo che i sistemi informatici e la gestione dei dati siano conformi alle normative vigenti, applicabili alle

PMI (es. NIS2, PSNC, GDPR) e agli standard di settore.

- **La formazione e la consapevolezza**, per assicurare che il personale e i professionisti ICT siano adeguatamente formati e consapevoli delle minacce esistenti..
- **La collaborazione e la condivisione di esperienze ed informazioni** con altre organizzazioni per rafforzare la postura di sicurezza complessiva e adottare le migliori pratiche disponibili.



Stabilire gli obiettivi di sicurezza è un processo continuo e dinamico che deve tenere conto dell'evoluzione delle minacce informatiche, delle tecnologie e dell'ambiente operativo dell'azienda. È buona prassi che l'impresa definisca tali obiettivi già in fase di pianificazione strategica, **assicurandone una revisione periodica nel tempo, in coerenza con le trasformazioni interne ed esterne.** Di seguito, alcuni momenti chiave nella vita dell'organizzazione in cui è opportuno stabilire o aggiornare gli obiettivi di sicurezza:

- **Avvio dell'attività:** prima di avviare una nuova attività di business, **è essenziale stabilire gli obiettivi di sicurezza per garantire che la protezione e la disponibilità dei dati** siano previsti in maniera prioritaria all'interno del processo di sviluppo.

- **Adozione di nuove tecnologie:** prima di adottare nuove tecnologie, sistemi, applicazioni o servizi **è importante verificare la compatibilità con gli obiettivi di sicurezza, per tutelare i dati e i sistemi e proteggerli** dalle minacce informatiche.

▪ **Aggiornamenti o migrazioni dei sistemi:** durante tali processi è fondamentale rivedere gli obiettivi prefissati per garantire che siano allineati con le nuove configurazioni o infrastrutture.

▪ **Cambiamenti dell'ambiente operativo:** se ci sono cambiamenti significativi, come l'espansione geografica, nuove linee di prodotti, servizi o l'adozione dello smartworking, è necessario rivedere e adattare gli obiettivi in funzione del nuovo contesto.

▪ **Dopo un incidente cyber: essenziale rivedere gli obiettivi di sicurezza e apportare le opportune modifiche** per prevenire il ripetersi di eventi simili, anche qualora l'impatto sia stato contenuto.

Questo processo contribuisce a rafforzare la resilienza complessiva dell'organizzazione.

▪ **Revisioni periodiche:** è buona prassi rivedere gli obiettivi prefissati con cadenza periodica, per **garantirne il costante allineamento rispetto all'evoluzione delle minacce informatiche**, agli sviluppi tecnologici e agli aggiornamenti normativi di settore.

Cosa causa l'assenza di obiettivi adeguati e una scarsa diffusione della cultura cyber all'interno dell'organizzazione?

La mancanza di obiettivi per migliorare la sicurezza **aumenta il rischio di subire attacchi cyber che possono portare ad interruzioni parziali o totali dei servizi, perdita e/o diffusione di informazioni riservate con impatti rilevanti** per il business dell'organizzazione e, in alcuni casi, conseguenze, sanzionatorie e/o legali. L'effetto di un incidente informatico può essere amplificato, nel caso l'organizzazione sia parte della filiera di erogazione di servizi essenziali, arrivando potenzialmente fino ad avere impatti per il Sistema Paese.

L'assenza di obiettivi di sicurezza chiari e condivisi, così come la gestione inadeguata di incidenti informatici, **può compromettere la fiducia di clienti e investitori nella capacità dell'organizzazione di proteggere i dati e garantire la continuità operativa**. Tale perdita di fiducia può avere ricadute significative sulla possibilità di attrarre investimenti, consolidare i rapporti commerciali e ampliare la base clienti.

La mancata diffusione di una cultura cyber all'interno dell'organizzazione, **porta a considerare la cybersicurezza un aspetto secondario**, non integrato nelle responsabilità operative e strategiche, e spesso percepito esclusivamente come un costo. Questa visione limita l'integrazione della sicurezza nei processi aziendali, con il rischio di sviluppare prodotti e servizi intrinsecamente vulnerabili, sui quali diventa poi difficile intervenire per contenere o gestire i rischi di interruzione dell'attività. **Ne possono derivare gravi conseguenze in termini di divulgazione non autorizzata di informazioni, con impatti reputazionali, economici e operativi anche rilevanti.**

2

Attenzione al quadro normativo di riferimento per la tua organizzazione

AZIONI CHIAVE

1. Conosci il quadro normativo applicabile alla tua organizzazione
2. Definisci gli adeguati presidi di sicurezza per essere conforme al quadro normativo di riferimento.
3. Mantieniti costantemente aggiornato sull'evoluzione del quadro normativo di riferimento e assicurati che l'organizzazione operi in piena conformità.

CONTENUTI DI DETTAGLIO

Conoscere e comprendere il contesto normativo del settore in cui si opera, è di fondamentale importanza per un'organizzazione. **Molte delle norme applicabili alle aziende nel contesto cyber forniscono indicazioni utili per l'innalzamento del livello di resilienza alle minacce cyber**, oltre che le regole, le direttive e i vincoli che l'organizzazione deve seguire e rispettare per ottemperare alle prescrizioni normative.

Qualora l'azienda operi o offra servizi fuori dall'Italia o dall'Europa, è determinante estendere le analisi allo specifico Paese. Oltre alle fonti normative ufficiali, è utile consultare siti web istituzionali al fine di individuare la disciplina applicabile al contesto aziendale che aiutino l'analisi della disciplina applicabile al contesto aziendale. In Italia, tra le normative più rilevanti in materia di cybersicurezza – molte delle quali di derivazione europea – si segnalano in particolare:

- **Decreto Legislativo n. 138/2024:** recepisce la Direttiva NIS³ dell'Unione Europea (UE), che mira a garantire l'aumento del livello di sicurezza informatica del tessuto produttivo e delle Pubbliche Amministrazioni e rafforza quanto già previsto dal precedente quadro NIS⁴, ampliandone il campo

di applicazione ed estendendo gli obblighi di notifica degli incidenti. La norma inoltre rafforza i poteri di supervisione, struttura maggiormente i meccanismi e gli organi preposti alla risposta agli incidenti e alla gestione della crisi.

³ Direttiva 2022/2555/UE.

⁴ Direttiva 2016/1148/UE.

▪ **Decreto legislativo n. 105/2019:**

convertito con modificazioni dalla Legge n. 133/2019, istituisce il c.d. Perimetro di Sicurezza Nazionale Cibernetica (PSNC) con l'obiettivo di assicurare un livello elevato di sicurezza delle reti, dei sistemi informativi e dei servizi informatici (beni ICT) delle amministrazioni pubbliche, degli enti e degli operatori nazionali, pubblici e privati da cui dipende l'esercizio di una funzione essenziale dello Stato, ovvero la prestazione

di un servizio essenziale rafforzando, tra l'altro, il presidio delle loro catene di fornitori.

▪ **Regolamento Generale Sulla Protezione Dei Dati Personali o General Data Protection Regulation (GDPR)⁵ dell'Unione Europea:**

direttamente applicabile in Italia; stabilisce regole rigorose sulla protezione dei dati personali, inclusi requisiti stringenti in materia di sicurezza informatica e notifica delle violazioni dei dati.

Direttiva NIS2

La Direttiva NIS2, recepita con Decreto Legislativo n. 138/2024, è stata emanata per rafforzare ulteriormente il quadro della sicurezza cibernetica a livello europeo.

La Direttiva NIS2 mira a raggiungere i seguenti obiettivi:

1. Richiamare gli Stati membri alla dovuta attenzione alla sicurezza informatica;

2. Rafforzare la cooperazione europea tra le autorità di sicurezza informatica;

3. Richiedere ai principali soggetti dei settori chiave della nostra società di **adottare misure di sicurezza e segnalare eventuali incidenti.**



L'ambito di applicazione della Direttiva NIS2 **è stato notevolmente ampliato rispetto a quello della Direttiva NIS e sarà necessario**, per un insieme di organizzazioni, verificare se ricadono nell'ambito di applicazione definito con i relativi criteri dalla norma, e non più necessariamente **in base ad una identificazione degli enti interessati da parte delle autorità nazionali competenti**. Un'organizzazione rientra nell'ambito di applicazione NIS2 se:

▪ **Opera in uno dei (sotto) settori e tipologie di servizi elencati negli allegati della Direttiva;**

▪ **Ricade in alcuni parametri di dimensione organizzativa come di seguito rappresentati.**

⁵ Regolamento 2016/679/UE

La Direttiva NIS2 introduce nuovi settori, ma anche tipi di entità all'interno dei settori esistenti, ovvero:

- **settori ad alta criticità:** energia, trasporti, spazio, bancario, infrastrutture del mercato finanziario, sanità, acqua potabile e acque reflue⁶;
- **altri settori critici:** servizi postali e di corriere, gestione dei rifiuti, fabbricazione, produzione e distribuzione di prodotti chimici, ricerca⁷.

Un'organizzazione che opera nei settori sopra elencati rientra nel campo di applicazione della NIS2 se è **un'impresa di grandi o medie dimensioni**. **Le piccole e microimprese** (ossia quelle con meno di 50 dipendenti e un fatturato annuo, o un totale di bilancio annuo, inferiore a 10 milioni di euro – condizioni da considerarsi cumulative), **salvo specifiche eccezioni⁸**, sono escluse dal suo campo di applicazione. **L'analisi per identificare puntualmente se si ricada o meno nel campo di applicazione della NIS2, così come recepita negli Stati membri, risulta dunque fondamentale per una PMI.**

PSNC

L'istituzione del PSNC, in riferimento ai settori governativo, dell'interno, della difesa, dello spazio e aerospazio, dell'energia, delle telecomunicazioni, dell'economia e finanza, dei trasporti, dei servizi digitali, delle tecnologie critiche e degli enti previdenziali e del lavoro, prevede l'individuazione e l'aggiornamento periodico delle funzioni e dei servizi essenziali, la cui interruzione o compromissione potrebbe arrecare un pregiudizio alla sicurezza nazionale

I soggetti che gestiscono servizi inclusi nel Perimetro di Sicurezza Nazionale Cibernetica, tra i principali adempimenti previsti dalla normativa, sono tenuti, tra l'altro, a:

- **Effettuare e revisionare annualmente un'analisi del rischio** che permetta di redigere una lista degli asset ritenuti "strategici" (c.d. beni ICT) per la fornitura dei servizi e funzioni essenziali di rispettiva pertinenza.
- **Adottare misure che assicurino elevati livelli di sicurezza per i beni ICT**, imponendole, tramite contratti, anche ai fornitori che operano nella propria filiera.
- **Notificare eventuali incidenti al Computer Security Incident Response Team (CSIRT)** attivo presso l'Agenzia per la cybersicurezza nazionale (ACN).
- **Comunicare al Centro di Valutazione e Certificazione Nazionale (CVCN) – l'intenzione di acquisire beni, sistemi e servizi ICT** da impiegare sui beni ICT e appartenenti a determinate categorie di cui al DPCM 15 giugno 2021.

⁶ Per l'elenco esaustivo vedi Allegato I della Direttiva.

⁷ Per l'elenco esaustivo vedi Allegato II della Direttiva.

⁸ In alcuni settori, le entità, indipendentemente dalle dimensioni, sono designate come "essenziali", ad esempio, i fornitori di reti pubbliche di comunicazione elettronica, le entità designate come critiche a livello nazionale ai sensi del regolamento di esenzione per categoria, i servizi governativi (a livello centrale), fornitori di servizi fiduciari qualificati, registri dei nomi di dominio di primo livello e fornitori di servizi DNS. Oltre a queste norme, le autorità nazionali possono anche designare specificamente le entità come "essenziali" o "importanti", ad esempio quando sono l'unico fornitore di servizi o quando un'interruzione nella fornitura di servizi potrebbe avere conseguenze significative per la sicurezza pubblica o la salute pubblica.

GDPR

Considerando il forte collegamento fra la sicurezza dei dati e la protezione dei dati personali **una delle ulteriori norme da tenere in considerazione è il Regolamento Europeo GDPR, integrato anche da norme nazionali in materia di privacy**, che disciplina la protezione dei dati personali dei cittadini e delle organizzazioni sul territorio nazionale ed europeo.

In conformità al regolamento GDPR e alla normativa nazionale, **tutte le PMI che trattano o conservano dati personali appartenenti a residenti dell'Unione Europea (UE) o dello Spazio Economico Europeo (SEE), devono garantire, per la loro protezione, lo svolgimento di adeguati controlli di sicurezza, sia in caso i dati siano gestiti internamente, sia in caso siano affidati a terze parti**. Ciascuna PMI dovrà accertarsi di adottare gli opportuni presidi tra quelli previsti dal Regolamento GDPR, in base al contesto e al settore di business in cui si opera.

Inoltre, **la PMI dovrà valutare la nomina di un responsabile che operi per garantire la conformità e l'applicazione delle normative sulla protezione dei dati all'interno dell'organizzazione** e un responsabile della protezione dei dati personali (DPO), in base a quanto previsto dall'art. 37, par. 1, lettere b) e c), del GDPR. Per i casi esenti da obbligo, resta comunque fortemente raccomandata la designazione di tale figura.



Altri possibili ambiti di interesse

Un altro ambito regolamentato, potenzialmente applicabile a livello nazionale in Italia, riguarda le PMI che forniscono servizi cloud alla Pubblica Amministrazione. **Le PMI che ricadono in questa condizione devono presentare istanza per qualificarsi e, funzionalmente alla fattispecie di dati trattati dal servizio oggetto di qualifica, devono garantire adeguati requisiti di cybersicurezza**. Infine, per le PMI che si configurano come fornitori di servizi fiduciari

⁹ Dal 25 maggio 2018 è divenuto pienamente applicabile in tutti gli Stati membri il Regolamento UE 2016/679, noto come GDPR (General Data Protection Regulation) – relativo alla protezione delle persone fisiche con riguardo al trattamento e alla libera circolazione dei dati personali.

(ad esempio fornitori di servizi di firma digitale e posta elettronica certificata) si applica, inoltre, il Regolamento eIDAS (electronic IDentification Authentication and Signature) - Regolamento UE 2014/910 sull'identità digitale - con l'obiettivo di fornire una base normativa a livello comunitario per i servizi fiduciari e i mezzi di identificazione elettronica degli Stati membri.

Oltre al quadro normativo generale, **è fondamentale che tutti i soggetti che operano all'interno delle PMI, ciascuno per quanto di competenza, si tengano sempre aggiornati in relazione al quadro normativo vigente.** È auspicabile che le PMI investano, anche per il tramite delle associazioni di categoria, su un processo di aggiornamento e monitoraggio periodico, specie con riguardo alle normative suscettibili di variazioni nel tempo.

Che rischi comporta una scarsa attenzione al quadro normativo di riferimento?

La mancata osservanza dei vincoli normativi applicabili espone l'organizzazione a gravi rischi di **non conformità nella gestione della sicurezza dei sistemi e dei dati, con conseguenti sanzioni.**

L'assenza di un'adeguata conoscenza del quadro normativo e delle misure da adottare per garantire livelli di sicurezza adeguati **accresce significativamente la probabilità di subire incidenti informatici.** Tali eventi possono generare impatti rilevanti in termini di perdite economiche, danni reputazionali e compromissione del vantaggio competitivo.

Nei casi più critici, questa condizione può portare a provvedimenti di sospensione delle attività fino alla cessazione definitiva del business.

3

Acquisisci consapevolezza sugli asset (processi, sistemi e dati) vitali per il tuo business e supporta la loro protezione.

AZIONI CHIAVE

1. Identifica e riconosci gli asset (processi, sistemi e dati) **fondamentali per il tuo business** (sia interni che esterni).

2. Analizza periodicamente i potenziali rischi per i tuoi asset e intraprendi azioni che possano mitigarne gli impatti.

3. Non sottovalutare i rischi sugli asset gestiti dai tuoi fornitori ma assicurati che anche loro adottino contromisure adeguate.

4. Assicurati di avere all'interno della tua organizzazione, personale esperto che sappia valutare i rischi. In alternativa rivolgiti a professionisti in grado di fornirti questo supporto.

CONTENUTI DI DETTAGLIO

Avere piena consapevolezza degli asset fondamentali per il business (processi, sistemi e dati), ed identificare chiaramente quelli più critici, **è fondamentale per ciascuna organizzazione**. Non è possibile e non è utile proteggere tutto con lo stesso livello di sicurezza e l'identificazione degli asset fondamentali dell'organizzazione è un passo chiave per ottimizzare gli sforzi e le risorse. Per questo scopo, **è importante individuare le minacce** (correlate ad ogni bene, dato, azione, risorsa, attività o sistema) **e le condizioni che possono portare ad eventi malevoli accidentali o intenzionali** con conseguenze dannose per l'organizzazione.

È importante quindi che ciascuna PMI identifichi quali siano gli asset più critici per l'organizzazione (sia interni che esterni), valuti i rischi annessi e introduca azioni che ne mitighino gli impatti.

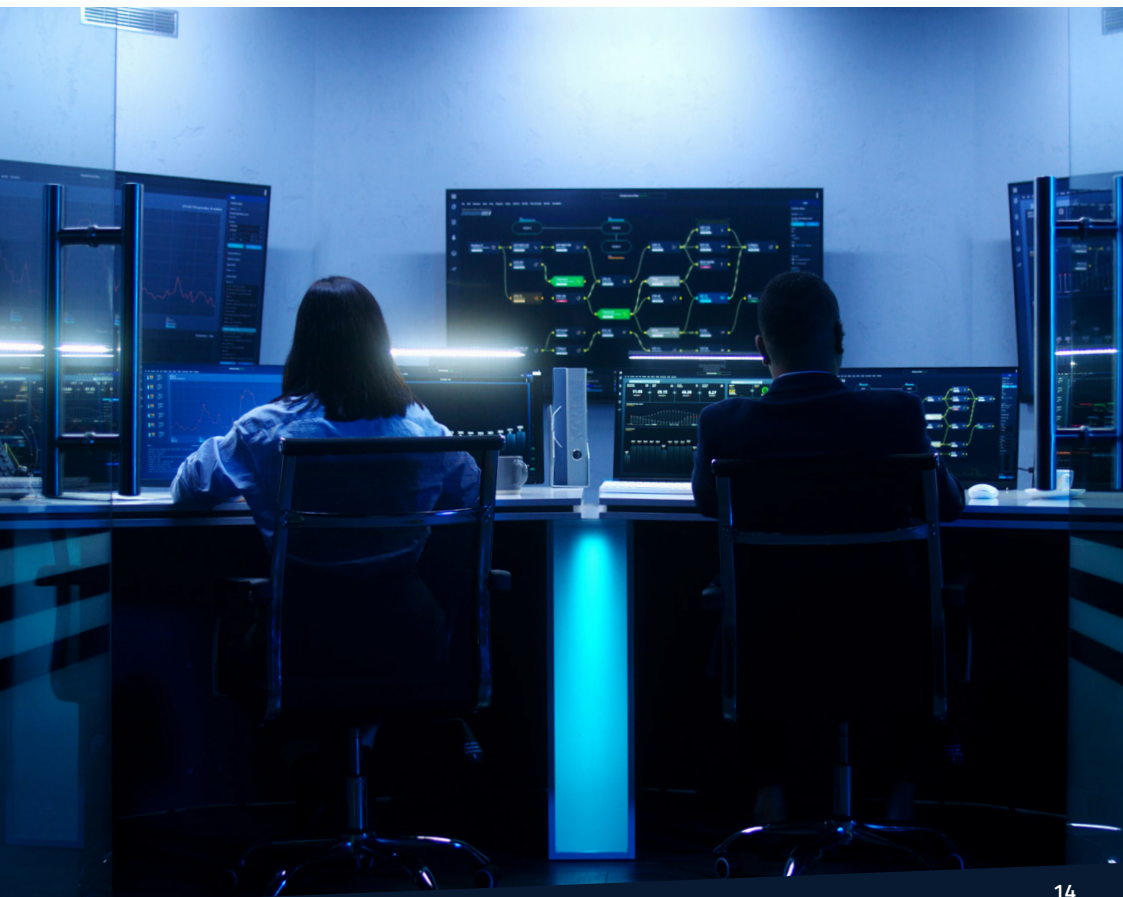
Qualsiasi organizzazione che utilizzi tecnologie digitali o gestisca dei dati è esposta al rischio cyber. Spesso infatti, gli avversari cercano di violare i sistemi di un'organizzazione attraverso punti vulnerabili, interni all'organizzazione o fuori dai suoi confini, attraverso lo sfruttamento di punti di ingresso fuori dal controllo diretto delle organizzazioni, ad esempio tramite fornitori terzi e partner. Perciò, **non è sufficiente che le organizzazioni si concentrino sulla protezione dei dati e sistemi informativi, ma è necessario incoraggiare anche il miglioramento delle pratiche di cybersicurezza dei servizi gestiti dai fornitori.**

L'analisi del rischio permette di individuare le contromisure necessarie per limitare i danni operativi, economici e reputazionali a cui l'impresa può essere esposta.

Questa analisi deve essere orientata sia verso gli asset interni dell'organizzazione, sia verso quelli esterni (affidati ai fornitori esterni o terze parti).

Avere a disposizione dell'organizzazione personale esperto, in grado di valutare i rischi, a cui gli asset sono esposti, e implementare le opportune azioni di mitigazione degli stessi, **è di fondamentale importanza per identificare e valutare efficacemente minacce e vulnerabilità che potrebbero compromettere la sicurezza dell'organizzazione.**

In assenza di un team di esperti cyber interno all'organizzazione, è consigliabile rivolgersi a professionisti terzi specializzati che possano fornirti questo supporto.



Cosa causa la mancanza di consapevolezza nella protezione degli asset aziendali?

La mancata identificazione degli asset critici compromette la capacità dell'organizzazione di condurre analisi del rischio efficaci, ostacolando l'individuazione puntuale di minacce, vulnerabilità e relative contromisure. Questo aumenta sensibilmente la probabilità di violazioni e compromissioni.

In qualsiasi organizzazione, indipendentemente dalle dimensioni, **l'identificazione degli asset fondamentali rappresenta il primo passo per innalzare e mantenere adeguati livelli di sicurezza**, mitigando gli effetti di eventuali attacchi informatici. Va tuttavia sempre considerata l'esistenza di un rischio residuo.

Trascurare tale attività significa disperdere risorse, frammentare gli investimenti e ridurre l'efficacia complessiva delle misure adottate. Inoltre, **l'assenza di una valutazione regolare dei rischi cyber rende più complesso individuare contromisure appropriate**, aumentando la vulnerabilità dell'intera organizzazione.



Seleziona e supporta un responsabile per la cybersicurezza (interno o esterno)

AZIONI CHIAVE

1. Nomina un responsabile per la cybersicurezza (interno o esterno)

per individuare i principali obiettivi di sicurezza per la tua organizzazione e per individuare un'efficace gestione degli incidenti.

2. Assicura un adeguato supporto al responsabile per la cybersicurezza,

affinché possa sviluppare e implementare un programma solido e strutturato, capace di garantire nel tempo elevati livelli di protezione per i sistemi aziendali.

3. Pianifica con il responsabile per la cybersicurezza allineamenti periodici

per monitorare i progressi, gli ostacoli e garantire coerenza con gli obiettivi di sicurezza e della strategia aziendale, anche attraverso la predisposizione e la promozione di programmi di formazione e consapevolezza.

4. Assicurati che i ruoli e le responsabilità del responsabile per la cybersicurezza siano chiaramente definiti e pienamente compresi da tutto il personale dell'organizzazione.

CONTENUTI DI DETTAGLIO

Nel contesto odierno, **le minacce cyber sono una sfida cruciale per le organizzazioni**. Per garantire un adeguato livello di cybersicurezza all'interno dell'organizzazione, **è opportuno identificare e rendere noto all'interno dell'azienda un responsabile per la cybersicurezza**. In caso non sia possibile nominare una persona interna all'organizzazione, si può fare ricorso a personale esterno, purché sia chiaro il suo mandato all'interno dell'organizzazione.

Questa figura deve possedere competenze adeguate ed essere in grado di individuare gli obiettivi di sicurezza più rilevanti per l'organizzazione. Sulla base di tali obiettivi, e con il supporto della dirigenza, è chiamata a sviluppare un programma di cybersicurezza solido e coerente, volto a garantire nel tempo un elevato livello di protezione dei sistemi aziendali.

Il responsabile per la cybersicurezza deve essere coinvolto nei processi aziendali (principali e di supporto) non solo per **supervisionare le attività di identificazione e valutazione dei rischi** di cybersicurezza, ma anche per **fornire supporto tecnico sulla conformità dei sistemi aziendali alle normative vigenti in materia**. È compito della dirigenza **garantire che siano fornite al responsabile per la cybersicurezza tutte le risorse necessarie per una corretta gestione della cybersicurezza all'interno dell'organizzazione**: personale, software, servizi, hardware, formazione e promozione di una cultura della sicurezza, sviluppo di politiche e procedure efficaci e supporto durante gli incidenti. In particolare, la dirigenza deve affidare al responsabile per

la cybersicurezza la responsabilità della gestione degli incidenti di sicurezza informatica, Ciò implica definire con precisione le interfacce organizzative, le attività da svolgere e le tecnologie da adottare per garantire una risposta tempestiva ed efficace a eventuali minacce.

È inoltre di fondamentale importanza che il responsabile per la cybersicurezza sia pienamente consapevole dei punti di contatto interni ed esterni coinvolti nella gestione dell'incidente, inclusi fornitori e terze parti, così da poter attivare prontamente le azioni necessarie in caso di emergenza..

Inoltre, la dirigenza, per supportare adeguatamente il responsabile per la cybersicurezza, **deve intervenire nella pianificazione degli aggiornamenti periodici relativi al livello di sicurezza aziendale.**

Questo coinvolgimento è fondamentale per monitorare sia i progressi sia le eventuali criticità riscontrate, e per garantire che il piano di cybersicurezza resti coerente con gli obiettivi di sicurezza e con la strategia complessiva dell'organizzazione. È consigliabile che questi allineamenti vengano svolti almeno ogni tre mesi, o con maggiore frequenza in caso di problemi o incidenti di sicurezza da gestire.



Quali conseguenze comporta l'assenza o il mancato adeguato supporto di un responsabile per la cybersicurezza?

L'assenza di un responsabile per la cybersicurezza comporta la mancanza di competenze specialistiche dedicate, nonché di una leadership chiara e di una direzione strategica per fronteggiare le minacce cyber e proteggere l'organizzazione.

Inoltre, senza questa figura di riferimento, **rischiano di venire meno il coordinamento e la comunicazione tra le diverse aree aziendali**, elementi fondamentali per l'implementazione, il monitoraggio e il mantenimento dei presidi di sicurezza a tutela degli asset critici.

La mancanza di un responsabile per la cybersicurezza o un suo supporto non adeguato porta a una scarsa consapevolezza della sicurezza tra i dipendenti, aumentando il rischio di errori umani o comportamenti non sicuri.

In caso di violazione dei dati o altri incidenti di sicurezza, **l'assenza di un responsabile per la cybersicurezza ostacola una gestione efficace della crisi e amplifica sia l'entità del danno che la complessità delle attività di contenimento e risoluzione**.

5

Predisponi iniziative di formazione e/o di awareness

AZIONI CHIAVE

1. Garantisci ai dipendenti l'accesso a corsi di formazione, iniziative di awareness e canali di aggiornamento periodici sulla cybersicurezza.

2. Al termine di ogni corso, valuta il livello di conoscenze e competenze acquisite dal personale. Qualora i risultati non siano soddisfacenti, pianifica una sessione di approfondimento successiva.

3. Garantisci che il personale tecnico riceva la formazione necessaria per rispondere prontamente ed in maniera efficace agli incidenti di sicurezza.

4. Non sottovalutare la supply chain (fornitori, clienti e altre terze parti), verifica che anche i tuoi fornitori seguano corsi e siano aggiornati sulle principali minacce cyber e valuta se fornire indicazioni anche a clienti ed ulteriori utenti esterni.

CONTENUTI DI DETTAGLIO

Il fattore umano è il vettore d'attacco maggiormente utilizzato dai cybercriminali in quanto spesso caratterizzato da una scarsa consapevolezza e conoscenza dei rischi e delle minacce legati alla sicurezza informatica. Per questo motivo è **fondamentale diffondere conoscenza all'interno dell'organizzazione in merito ai rischi informatici e incentivare i dipendenti all'utilizzo di comportamenti consapevoli** nell'utilizzo del web, dei dispositivi mobili e dei sistemi informatici in generale.

Un elemento cruciale per garantire la cybersicurezza, consiste nel coinvolgere i dipendenti delle PMI e renderli consapevoli dei rischi e delle minacce connessi all'utilizzo non solo degli strumenti di lavoro e delle infrastrutture critiche, ma anche dei dispositivi personali.

Per rafforzare la conoscenza e la consapevolezza dei dipendenti in materia di cybersicurezza, è fondamentale condurre una valutazione accurata delle loro competenze e del livello di preparazione rispetto alle principali minacce. Questo consente di individuare le aree critiche su cui intervenire attraverso programmi di formazione mirata, compiendo così un primo passo concreto verso il consolidamento di una cultura della sicurezza informatica all'interno dell'organizzazione.

Per raggiungere l'obiettivo indicato, è fondamentale allocare adeguate risorse in:

- **Corsi di formazione** per lo sviluppo e il potenziamento di una cultura della cybersicurezza.

- **Materiali informativi e aggiornamenti periodici**, come newsletter o nozioni base di igiene cibernetica diffuse tramite i canali multimediali aziendali, **rappresentano**

- strumenti utili a promuovere la consapevolezza dei dipendenti in materia di cybersicurezza.**

- **Iniziative di sensibilizzazione**, come esercitazioni simulate, **finalizzate a rafforzare la preparazione del personale** nella gestione di potenziali scenari di minaccia informatica.

Per implementare queste iniziative, **è necessario predisporre un piano che garantisca a tutto il personale — in particolare a coloro che ricoprono ruoli critici — un'adeguata preparazione**, assicurando che siano in grado di agire secondo quanto previsto da politiche, linee guida e procedure aziendali. Al termine di ciascuna sessione, o dopo alcuni mesi, **è infatti buona pratica eseguire test o altre forme di valutazione per verificare le conoscenze e le competenze acquisite.**

È fondamentale, inoltre, **che tutta la supply chain** (fornitori, clienti e altre terze parti) **raggiunga un livello di consapevolezza pari a quello del personale interno all'azienda.** A tal fine, è opportuno definire contenuti e modalità formative adeguate ai diversi destinatari e prevedere risorse dedicate per il supporto e l'erogazione.

Quali rischi comporta l'assenza di iniziative strutturate di formazione e/o di awareness?

La mancanza di consapevolezza sulle principali minacce informatiche e sulle modalità con cui prevenire eventuali incidenti comporta un'alta vulnerabilità dell'organizzazione agli attacchi (interni ed esterni). Inoltre, può favorire comportamenti inconsapevoli o non conformi, che facilitano la sottrazione di informazioni riservate da parte degli attaccanti. Questo può tradursi in violazioni della cybersicurezza e della privacy, con conseguenze legali, sanzioni e danni reputazionali per l'azienda.

La mancata pianificazione di attività di formazione e/o iniziative di awareness, innalza il rischio di essere vittime di attacchi di social engineering¹⁰, tra i quali sono particolarmente diffusi i tentativi di phishing. I dipendenti, non supportati nel riconoscimento di questi attacchi, possono essere ingannati e indotti in comportamenti che portano a violazioni di cybersicurezza con compromissione del patrimonio informativo e/o interruzioni dei servizi di business.

¹⁰ Il social engineering è una tecnica di attacco che sfrutta l'errore o la debolezza umana piuttosto che le vulnerabilità tecniche dei sistemi informatici e di rete, per indurre le persone a compiere azioni dannose inconsapevolmente. Tra queste, ad esempio, il download di malware, la condivisione di informazioni personali o riservate dell'organizzazione.

6

Verifica accuratamente l'affidabilità dei fornitori, dei prodotti e servizi e la solidità dei relativi contratti.

AZIONI CHIAVE

1. Per i tuoi servizi, seleziona fornitori che soddisfino adeguati livelli di sicurezza, che siano certificati e che forniscano garanzie sull'utilizzo delle migliori pratiche (es. ISO27001).

2. Definisci sempre formule contrattuali dettagliate a supporto delle attività esternalizzate e **prevedi requisiti più stringenti** in funzione della criticità dei dati e dei servizi che affidi all'esterno.

3. Verifica che nei contratti con le terze parti

siano incluse, oltre alle clausole di sicurezza, **quelle relative alla conformità ai vincoli normativi del tuo settore.**

4. Richiedi se sui servizi affidati alle terze parti sono svolte attività di vulnerability assessment e/o penetration test per verificarne i corretti livelli di sicurezza.

5. Assicurati di prevedere opportune clausole per la gestione degli incidenti per fare in modo di essere avvisato e supportato dalle terze parti in caso di necessità.

CONTENUTI DI DETTAGLIO

È importante assicurarsi che tutti i fornitori, in particolare quelli che hanno accesso a dati e sistemi critici dell'organizzazione, o senza il contributo dei quali viene ad essere a rischio la continuità di processi chiave per il business aziendale, **soddisfino adeguati livelli di sicurezza.**

Prima di esternalizzare un servizio o acquistare un prodotto ICT, soprattutto in caso di un asset critico, **è fondamentale scegliere accuratamente i fornitori** e fare in modo che il responsabile per la cybersicurezza, o il personale tecnico addetto, verifichi i livelli di sicurezza offerti e, se soddisfacenti, li formalizzi in appositi documenti contrattuali. Dove disponibili, **è utile far riferimento all'ottenimento da parte del fornitore di certificazioni dei livelli di sicurezza di prodotti e servizi per utilizzarli come elemento di selezione in fase di acquisizione.**

La definizione dei requisiti di sicurezza a tutela degli asset affidati all'esterno deve basarsi sulla criticità dei dati coinvolti. I requisiti selezionati devono essere proporzionati al livello di sensibilità delle informazioni trattate da terze parti per conto dell'organizzazione. Dati di natura finanziaria o

sanitaria richiedono misure di sicurezza più rigorose rispetto a dati meno critici.

È quindi fondamentale **verificare che i contratti con le terze parti includano, qualora non già presenti, clausole specifiche relative alla cybersicurezza, che prevedano almeno le seguenti disposizioni:**

- **Requisiti di sicurezza, che presidino trasversalmente gli accessi, la protezione dei dati, la rete, il backup, la gestione degli incidenti** con la possibilità di verificarne il mantenimento e il presidio nel tempo.
- **Requisiti di conformità normativa del fornitore**, in relazione alle leggi, regolamenti e standard applicabili al settore in cui opera.
- **La previsione di un supporto collaborativo in caso di eventuali violazioni di sicurezza ed incidenti**, nel rispetto di tutte le conformità con

le normative vigenti (es. violazioni dei dati privacy c.d. data breach).

- **La previsione di attività di vulnerability assessment e/o penetration test periodiche** da parte del fornitore per tenere alto il livello di sicurezza delle loro infrastrutture e dei servizi da loro erogati.
- **La possibilità, dove opportuno, di ricevere report dettagliati su eventuali incidenti occorsi**, sul livello di aggiornamento (patching) dei sistemi e sulla documentazione relativa alla conformità normativa.



Il processo di selezione delle terze parti e dei fornitori IT rimane fondamentale. Si consiglia, al riguardo, di selezionare sempre partner affidabili che forniscano elevati presidi, posseggano certificazioni e dimostrino il rispetto delle migliori pratiche di sicurezza (es. ISO27001). Scegliere un fornitore selezionato e affidabile ti aiuta a garantire una maggiore protezione dei dati dell'organizzazione.

A seguire si riporta un esempio (indicativo e non esaustivo) di alcuni tra i principali requisiti di sicurezza da considerare e includere nelle clausole contrattuali con le terze parti:

- **Consentire l'accesso ai sistemi esclusivamente a personale autorizzato.**

In particolare, per applicativi, database o software contenenti informazioni riservate, è fondamentale garantire un'adeguata separazione dei ruoli e delle responsabilità, assicurando che l'accesso sia limitato unicamente al personale specificamente incaricato, in relazione alle attività operative di propria competenza.

- **Proteggere i dati, ad esempio mediante l'utilizzo di una crittografia forte, sia per i dati a riposo che in transito;** questo permetterà di proteggere le informazioni riservate durante il trasferimento e l'archiviazione.

- **Proteggere la rete dall'esterno, attraverso appositi firewall e zone demilitarizzate o DeMilitarized Zone (DMZ)** controllate ed isolate (tra la rete interna ed esterna)

e utilizzando per i collegamenti remoti un'apposita rete privata virtuale o Virtual Private Network (VPN), che garantisce la trasmissione dei dati su reti pubbliche in modo anonimo e sicuro.

- **Garantire un accesso sicuro ai sistemi, soprattutto se da remoto,** con la predilezione di politiche di password complesse e robuste o che richiedano l'utilizzo dell'autenticazione a più fattori o Multi Factor Authentication (MFA).

- **Garantire in caso di interventi di manutenzione, il tracciamento degli accessi o l'accesso limitato** solo per il tempo necessario a svolgere il lavoro, per proteggere i dati riservati di alcuni sistemi.

- **Garantire che i sistemi siano sempre aggiornati con le ultime patch di sicurezza** e gli ultimi aggiornamenti messi a disposizione dai vendor in linea con le migliori pratiche di sicurezza.

Cosa causa la scelta di fornitori non affidabili?

La scelta di fornitori non affidabili aumenta il rischio di essere vittima di attacchi informatici, con conseguenti danni economici per l'organizzazione e la perdita di reputazione e fiducia da parte degli stakeholder.

La mancanza di requisiti di sicurezza negli accordi contrattuali comporta una non adeguata protezione dei sistemi ed il verificarsi di violazioni dei dati, interruzioni all'operatività del business e non conformità normative con conseguenti danni reputazionali e perdite economiche.

La scelta di un fornitore con livelli di sicurezza inadeguati e privo di presidi efficaci espone non solo l'organizzazione al rischio di incidenti informatici, ma può anche compromettere l'intera supply chain, favorendo la diffusione di virus o altri software dannosi.

Lista degli acronimi

ACN	agenzia per la cybersicurezza nazionale
CSIRT	computer security incident response team
CVCN	centro di valutazione e certificazione nazionale
DMZ	demilitarized zone
DNS	domain name system
eIDAS	electronic identification authentication and signature
ENISA	european union agency for cybersecurity
GDPR	general data protection regulation
MFA	multi factor authentication
NIS	network and information security
PMI	piccole e medie imprese
PSNC	perimetro di sicurezza nazionale cibernetica
SEE	spazio economico europeo
UE	unione europea
VPN	virtual private network